

Requerimientos de Seguridad - Proyecto Kontrol+

1. Integrantes del Equipo

- **Juan Sebastian Garcia Silva** - Clase/Sección:2902

2. Descripción Breve del Proyecto

El proyecto **Kontrol+** es un sistema integral de Punto de Venta (POS) y Planificación de Recursos Empresariales (ERP) desarrollado bajo una arquitectura web utilizando Java, Spring Boot y MongoDB. El sistema permite la gestión centralizada de inventarios, registro de ventas, control de compras a proveedores y manejo de cuentas (por cobrar y por pagar). Como valor agregado, el sistema incorpora Inteligencia Artificial mediante modelos de Machine Learning (Weka/J48) para realizar predicciones inteligentes sobre ventas rápidas, riesgo de devoluciones y necesidad de promociones, optimizando así la toma de decisiones comerciales.

3. Requerimientos Funcionales y No Funcionales (Seguridad)

A continuación, se presenta el catálogo de requisitos de seguridad extraídos del análisis de funcionalidades, activos y amenazas del sistema Kontrol+, basándose en el estándar de definición de propiedades de seguridad.

ID	Tipo	Requisito	Amenaza
RS-001	Funcional	El sistema deberá autenticar a los usuarios (vendedores y administradores) mediante un formulario de login antes de permitir el acceso al Punto de Venta y al Dashboard.	Acceso no autorizado a la caja y datos de ventas.

ID	Tipo	Requisito	Amenaza
RS-002	Funcional	El sistema deberá controlar el acceso mediante roles, restringiendo la creación, edición y eliminación de usuarios únicamente al rol Administrador.	Escalamiento de privilegios.
RS-003	Funcional	El sistema deberá cerrar la sesión de forma segura e invalidar el contexto de seguridad cuando el usuario solicite finalizarla.	Uso indebido de sesiones (Session Hijacking).
RS-004	Funcional	El sistema deberá interceptar y rechazar automáticamente cualquier petición a las rutas administrativas si el usuario autenticado solo posee el rol Vendedor.	Acceso no autorizado a configuraciones críticas.
RS-005	No Funcional	Las contraseñas de los usuarios no deberán almacenarse en texto plano; deberán resguardarse en la base de datos utilizando el algoritmo de hash fuerte BCrypt.	Robo de credenciales por exposición de la base de datos.
RS-006	No Funcional	El mecanismo de control de acceso deberá aplicarse de manera centralizada a través de un filtro de seguridad que cubra todas las peticiones HTTP del sistema.	Evasión de controles de seguridad o acceso por URL directa.
RS-007	No Funcional	El sistema deberá asociar automáticamente cada transacción de venta al identificador del usuario autenticado que la realizó.	Falta de trazabilidad (No repudio) en las operaciones financieras.
RS-008	No Funcional	El sistema deberá mantener la confidencialidad de los datos sensibles (reportes financieros e información de clientes) asegurando que no sean expuestos en rutas públicas.	Exposición de información comercial sensible.